SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

Code of Conduct:

I **J. SAI DHEERAJ (192311191)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **J. SAI DHEERAJ**

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

o domain registration details,

o employee email addresses,

o technology stack,

o and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

1. Aim

To conduct a passive footprinting assessment of ABC Technologies by collecting publicly available information about its domain registration, employee email addresses, technology stack, and exposed subdomains without directly interacting with the company's servers.

2. Tools and their applications

Tool	Information collected	Purpose
WHOIS	Domain registrar, registration dates, name servers, and registrant details when public	Understand domain ownership and registration history
theHarvester	Publicly indexed email addresses, hosts, and subdomains	Identify publicly visible organizational information
Wappalyzer	Website technologies, frameworks, CMS, and analytics tools	Understand the publicly observable technology stack

DNSDumpster	DNS records, subdomains, and related infrastructure information	Map the organization's external digital footprint
Search engines	Public employee profiles, company pages, and indexed documents	Gather publicly available competitive intelligence

3. Procedure

Step 1: Collect domain registration details using WHOIS

whois example.com

Replace example.com with the authorized assessment domain. Review the registrar, creation and expiration dates, name servers, and publicly available registrant information.

Step 2: Find publicly indexed emails using theHarvester

theHarvester -d example.com -b duckduckgo -l 100

This searches a supported public source for information associated with the domain. The source may vary depending on the installed version and available configuration.

Step 3: Identify the technology stack

Use the Wappalyzer browser extension or its supported website technology lookup. Record technologies that can be observed publicly, such as the content management system, JavaScript frameworks, analytics services, and web server indicators.

Step 4: Discover publicly exposed subdomains

Use DNSDumpster or another passive DNS data source to identify publicly documented subdomains and associated records.

Examples of possible subdomain naming patterns include mail.example.com, support.example.com, and portal.example.com. These are examples, not confirmed findings.

4. How the tools support competitive intelligence

- WHOIS: Helps understand domain registration, registrar relationships, and infrastructure administration.
- theHarvester: Helps identify public contact information and potential communication channels.
- Wappalyzer: Reveals technologies that may indicate the company's technical capabilities and software ecosystem.
- DNSDumpster: Helps map publicly documented infrastructure and identify internet-facing services.
- Search engines: Help discover public announcements, job postings, technical documents, and organizational information.

5. Security risks and precautions

Collected information could be misused for targeted phishing, employee impersonation, technology-specific attacks, and infrastructure reconnaissance.

ABC Technologies should minimize unnecessary public disclosures, configure SPF/DKIM/DMARC, maintain secure web technologies, review DNS records, and train employees to recognize social engineering attacks.

Conclusion

Passive footprinting tools provide valuable competitive intelligence without directly probing the company's servers. The results help analysts understand the organization's public digital footprint and recommend improvements to its security posture.

Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

1. Aim

To verify whether an authorized target DNS server permits DNS zone transfers and explain how the resulting records may assist reconnaissance.

2. Tool required

- dig command-line DNS utility
- Kali Linux terminal
- An authorized target domain and authoritative DNS server

3. Procedure

Step 1: Identify the authoritative name servers

dig NS example.com

This command lists the name servers associated with the domain.

Step 2: Identify the target DNS server

Select an authoritative name server from the returned records.

Step 3: Test whether a zone transfer is permitted

dig AXFR example.com @ns1.example.com

Replace example.com and ns1.example.com with the authorized test domain and its actual authoritative server.

Step 4: Analyze the result

- Transfer succeeds: The output may contain a series of DNS records from the requested zone.
- Transfer fails or is refused: The server may be correctly restricting transfers, although network restrictions and server configuration can also affect the result.

A successful transfer should be evaluated against the organization's intended DNS configuration; some zones are deliberately published for approved secondary DNS servers.

4. Analysis of retrieved DNS records

DNS record	Purpose	Reconnaissance value
A	Maps a hostname to an IPv4 address	Helps identify hosts and their associated IP addresses
AAAA	Maps a hostname to an IPv6 address	Reveals IPv6-enabled infrastructure
MX	Identifies mail exchangers	Reveals email infrastructure
NS	Identifies authoritative name servers	Helps map DNS infrastructure
CNAME	Identifies hostname aliases	May reveal relationships between services
TXT	Contains text-based DNS information	May expose email security policies or other published configuration data

5. Security implications

If an unauthorized zone transfer succeeds, an attacker may obtain hostnames, mail server names, subdomains, and other DNS records. This information can make it easier to map an organization's infrastructure, identify potentially exposed services, and create convincing phishing messages.

A successful zone transfer does not, by itself, grant access to the systems identified in the records.

6. Countermeasures

1. Restrict AXFR requests to authorized secondary DNS servers.
2. Configure access control lists (ACLs) for approved server IP addresses.
3. Use TSIG authentication for zone transfers where supported.
4. Separate internal DNS zones from externally published DNS information.
5. Remove obsolete and unnecessary DNS records.
6. Monitor DNS logs for unexpected transfer requests.
7. Conduct regular authorized DNS configuration reviews.

Conclusion

The dig AXFR command helps verify whether a DNS server permits zone transfers. Unauthorized transfers can disclose valuable infrastructure information. Restricting transfers, authenticating authorized servers, and monitoring DNS activity reduce the risk of information disclosure.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

1. Identification of the attack

The scenario describes a phishing attack, specifically an email-based credential-harvesting attempt.

The email pretends to originate from the IT department and creates urgency by claiming that employees must verify their credentials because of a security update. The objective is to persuade employees to visit a fraudulent link and disclose their login information.

2. Social engineering techniques used

- Impersonation: The attacker pretends to be a trusted IT employee.
- Urgency: The alleged security update pressures employees to act quickly.
- Fear: The message may imply that an account will be blocked or become insecure.
- Deceptive links: The supplied link may lead to a fraudulent login page.
- Credential harvesting: The attacker attempts to collect usernames and passwords.

3. Countermeasures employees should follow

1. Verify the sender

Check the full sender address and domain. A familiar display name does not guarantee that the email is legitimate.

2. Inspect the link

Check the actual destination before opening it. Do not enter credentials into a website reached through an unexpected email.

3. Verify through an independent channel

Contact IT support using a known phone number, official service desk, or bookmarked company portal rather than replying to the suspicious email.

4. Never disclose passwords

Legitimate IT staff should not ask employees to submit their passwords through an email link. Use the organization's official password-management or account-recovery process.

5. Report the email

Use the company's phishing-reporting button or notify the security team. Avoid forwarding the email to other employees unnecessarily.

4. Organizational security measures

Security measure	How it helps

Multi-factor authentication (MFA)	Adds another authentication layer if a password is stolen; phishing-resistant MFA provides stronger protection.
Email filtering	Detects and blocks suspicious messages, malicious links, and attachments.
SPF, DKIM, and DMARC	Help reduce email spoofing using the organization's domain.
Security awareness training	Teaches employees to identify phishing indicators and report suspicious messages.
URL protection	Blocks known phishing websites and suspicious destinations.
Incident response procedures	Enable quick account protection, investigation, and containment following a suspected compromise.

5. What should an employee do if credentials have already been entered?

1. Report the incident to IT or the security team immediately.
2. Change the compromised password through the official website using a trusted device.
3. Revoke active sessions and reset affected authentication methods if instructed by the security team.
4. If the same password was reused elsewhere, change it on those accounts too.
5. Follow the organization's incident-response instructions and preserve the suspicious email for investigation.

6. How these actions prevent credential theft

Sender verification helps identify impersonation. Link inspection reduces the likelihood of visiting fraudulent websites. Independent verification confirms whether the request is genuine. Refusing to disclose passwords prevents attackers from obtaining credentials, while MFA can reduce the impact of stolen passwords. Reporting suspicious messages also helps security teams block similar attacks against other employees.

Conclusion

The scenario is an email phishing attack that uses urgency and IT impersonation to steal credentials. Employees should verify senders, inspect links, confirm unusual requests independently, never disclose passwords, and report suspicious messages. Combined with MFA, email security controls, and continuous awareness training, these measures significantly reduce credential-theft risk.